

Security Assessment — Client

Engagement: Phase-1 security assessment · Date: 2026-07-15 · Overall severity: **Critical**

Critical: 1 · Medium: 1

AI-assisted draft. Must be reviewed and signed off by a human analyst before release. Reviewed by: _____ Date: _____

Executive summary

This Phase-1 assessment consolidated dynamic testing, static code analysis, and external attack-surface enumeration against the lab environment. SQL injection was confirmed both dynamically (two exploitable endpoints) and statically (three user-input-to-JDBC sinks), giving high confidence in an exploitable, high-impact weakness. External recon additionally surfaced several authentication-protected non-production environments and an exposed administration login. Remediation should prioritize parameterized queries and review of the exposed non-prod surface.

Findings

#	Severity	Conf.	Finding	Asset	CWE / OWASP / ATT&CK
1	Critical	High	SQL injection via user input flowing into JDBC queries	WebGoat SqlInjection endpoints + UserService.java:53, JWTHeaderKIDEndpoint.java:73	CWE-89 · A03:2021 – Injection · T1190
2	Medium	High	Administration console login exposed on the internet	admin.test.aiforyourwork.net	CWE-284 · A01:2021 – Broken Access Control · T1133

F1. SQL injection via user input flowing into JDBC queries **Critical**

confidence High · Static + Dynamic (corroborated)

Asset: WebGoat SqlInjection endpoints + UserService.java:53, JWTHeaderKIDEndpoint.java:73

Classification: CWE-89 · A03:2021 – Injection · T1190

Evidence: sqlmap confirmed injection on parameters `userid` and `action\_string`; semgrep found three JDBC sinks built by string concatenation of user-controlled input. Static and dynamic signals agree.

Remediation: Replace string-concatenated SQL with parameterized queries (PreparedStatement with bound parameters) at all identified sinks; add a regression test per fix.

F2. Administration console login exposed on the internet **Medium**

confidence High · Recon

Asset: admin.test.aiforyourwork.net

Classification: CWE-284 · A01:2021 – Broken Access Control · T1133

Evidence: Subdomain enumeration found an internet-reachable admin login (HTTP 401).

Remediation: Restrict the admin console to a VPN/allow-list; enforce MFA; monitor auth failures.

Attack surface

31 live hosts under the test domain; multiple non-production environments (staging, dev, qa, internal) and sensitive services (billing, payments, SSO, monitoring, webhooks) are publicly reachable, most behind a 401 auth challenge. Non-prod environments are a common weak point and should not be openly reachable.

Recommendations

1. Parameterize all identified SQL sinks (highest priority).
2. Remove or IP-restrict public access to non-production environments.
3. Place the admin and internal-tools logins behind VPN/allow-list + MFA.
4. Re-scan after remediation to confirm the injections are closed.

Methodology & scope

Automated tools — dynamic SQL-injection testing (sqlmap), static code analysis (semgrep + AI), and external attack-surface enumeration — against authorised lab targets. Tool output was consolidated and prioritized by a language model and reviewed by a human analyst before release.